
Cyber Tabletop Exercise

Law Firm Confidential Matter Access

Scenario generated from STIX 2.1 bundle: Legal Services TTX Inject Set

Target organization: Corporate Law Firm (legal-services)
Threat actor: Commercial Espionage Actor — motivation: competitive advantage
Core system: Legal Document Management System
Exercise date: 23 June 2026 Recommended duration: 90 minutes

This document is a facilitation-ready cyber tabletop exercise. It includes scenario framing, participant rules, phased injects, expected actions, decision points, facilitator notes, debrief prompts, and a MITRE ATT&CK; mapping.

1. Exercise Overview

Purpose

This tabletop exercise tests the organization's ability to identify, contain, investigate, and govern an incident involving unauthorized access to privileged legal matter files through a compromised attorney account. The scenario emphasizes attorney-client confidentiality, privilege preservation, client notification, evidence handling, crisis escalation, and secure restoration of account and matter access.

Agenda

- Opening, rules of engagement, and objectives.
- Scenario briefing and baseline assumptions.
- Four phased injects with facilitated discussion after each inject.
- Decision points covering containment, legal privilege, client communications, and evidence preservation.
- Final debrief, lessons learned, action owners, and MITRE ATT&CK; mapping.

Exercise Objectives

- Validate escalation paths between SOC/security operations, IT, General Counsel, practice leadership, privacy, records, communications, and executive leadership.
- Test decision-making around a potentially compromised attorney account and suspected exposure of privileged client matter files.
- Assess the organization's ability to preserve legal privilege and evidence while containing the incident.
- Evaluate client notification triggers, outside counsel engagement, insurance notification, and regulatory/privacy assessment processes.
- Identify improvements in identity controls, unmanaged device access, document management monitoring, and matter-level access governance.

Target Participants

- **Executive / firm leadership:** managing partner, COO, CRO, CISO, CIO, practice group leaders.
- **Legal and governance:** General Counsel, privacy officer, conflicts/ethics counsel, records management, outside counsel liaison.
- **Operational and technical:** SOC, incident response, IT operations, IAM, document management system owner, endpoint/security engineering.
- **Business support:** communications, client relationship partners, HR, vendor management, insurance/risk.

Scope and Assumptions

- The exercise is discussion-based. No production systems are touched.
- All facts are fictional and provided only for exercise purposes.
- Participants should respond according to their current roles, authorities, policies, and escalation procedures.
- The impacted system is the legal document management system used to store and access active matter files.
- The initial account appears valid, but its use is suspicious and traced to an unmanaged device.

2. Rules of Engagement and Facilitation Guidance

Rules of Engagement

- Real incidents take priority.
- There are no right or wrong answers; the purpose is to surface decision points and improvement opportunities.
- Suspend disbelief and respond as if the scenario is occurring today.
- Do not fight the scenario. Ask for clarification, then make a decision using available information.
- Keep client names, practice details, and sensitive internal processes confidential during and after the exercise.
- Facilitator may introduce additional facts to maintain momentum or test escalation paths.

Recommended Facilitation Model

- **Facilitator:** presents injects, controls time, prompts decisions, and avoids solving the scenario for participants.
- **Scribe:** records decisions, open questions, assumptions, action items, owners, and gaps.
- **Observers:** capture process gaps, role confusion, communication friction, and policy exceptions.
- **Participants:** respond from assigned roles and distinguish facts from assumptions.

Success Criteria

- A clear incident commander or crisis lead is identified early.
- SOC and legal teams coordinate containment without destroying evidence or privilege.
- Client impact assessment is disciplined, matter-specific, and documented.
- Internal and external communications are consistent, approved, and need-to-know.
- Notification decisions are tracked with legal rationale and timing.
- Post-incident actions improve identity, device, monitoring, and matter-access controls.

Exercise Artificialities

- Time is compressed; each inject may represent several hours of investigation.
- The facilitator may withhold some details to simulate uncertainty.
- No actual client or regulator communications should be sent.
- Technical details are simplified enough to support executive, legal, and operational discussion.

3. Scenario Narrative

Baseline Narrative

Unauthorized access to privileged legal matter files is detected from a compromised attorney account. The access involves the Legal Document Management System. The suspected adversary is a commercially motivated espionage actor seeking competitive advantage through access to sensitive client information, active merger and acquisition materials, litigation strategies, and privileged documents. The observed behavior aligns with use of valid credentials to access confidential matter files.

Business Context

- The firm represents clients in active M&A, litigation, and regulatory matters.
- Matter workspaces contain privileged documents, draft transaction materials, legal strategy, client communications, and sensitive business information.
- Attorneys frequently access documents remotely, but unmanaged device access to high-sensitivity matter files is restricted or closely monitored.
- The firm has confidentiality obligations to clients and professional responsibility obligations that may apply independently of privacy breach thresholds.

Threat Context

- **Threat actor:** Commercial Espionage Actor.
- **Motivation:** competitive advantage, likely through acquisition of confidential legal and business intelligence.
- **Primary attack pattern:** Valid Accounts Used to Access Confidential Matter Files.
- **Likely attack path:** stolen or phished attorney credentials, session reuse or token theft, unmanaged device access, high-volume document retrieval, possible staging/exfiltration.

Known Constraints at Start

- The attorney whose account is used is unavailable at the beginning of the exercise.
- The access appears authenticated, so immediate containment must balance business continuity, evidence preservation, and client confidentiality.
- Initial logs show file access and download volume but do not yet prove external disclosure.
- Several affected matters involve sensitive deadlines and partner/client relationships.

4. Exercise Timeline and Inject Flow

Inject	Exercise Time	Core Development	Primary Decisions
1	Day 1, 09:00	Security monitoring identifies unusually high-volume downloads from sensitive client matter files	Seize server, preserve logs, open incident bridge, identify affected files
2	Day 1, 10:30	The access is traced to an unmanaged device using a valid attorney account/device access, validate attorney activity	Contain account/device access, validate attorney activity, identify affected files
3	Day 1, 13:00	Affected files include active merger, acquisition, and litigation materials associated by matter code, privilege, legal holds, outside counsel, etc.	Assess client by matter code, privilege, legal holds, outside counsel, etc.
4	Day 1, 15:30	Partners assess whether client notification, privilege preservation, and incident notification/regulatory/privacy assessment, etc.	Decide client notification, regulatory/privacy assessment, etc.

Timing can be adjusted. For a 60-minute session, reduce each debrief to 5–7 minutes and prioritize decision points. For a 2-hour session, add technical breakout discussion after Injects 2 and 3.

Inject 1 – Unusual Download Volume

Exercise time: Day 1, 09:00

Inject statement to participants: Security monitoring identifies unusually high-volume downloads from sensitive client matter files.

Additional facts available if requested

- DMS monitoring detects a spike in downloads from three active matter workspaces.
- Downloads occurred between 02:17 and 03:04 using a senior attorney's account.
- The matter workspaces involve a pending acquisition, active litigation, and an internal investigation.
- The attorney's normal pattern is document review, not bulk download.

Discussion Questions

- 1 Who owns the initial incident response and severity classification?
- 2 What evidence must be preserved immediately?
- 3 Who should be informed, and what should not yet be communicated?
- 4 How do you distinguish legitimate attorney activity from account compromise?
- 5 What business or client deadlines may be affected if access is suspended?

Expected Actions / Good Practice Indicators

- Open a security incident and assign an incident lead.
- Preserve DMS, IAM, VPN, endpoint, and email logs.
- Contact the attorney through a trusted channel without tipping off a potential actor.
- Limit further high-risk downloads while avoiding unnecessary matter disruption.
- Engage General Counsel / ethics counsel early due to privilege and client confidentiality.

Facilitator Notes

Look for whether participants treat this as both a cyber incident and a legal confidentiality event. Challenge premature client notification before impact is understood, and challenge delays in evidence preservation.

Inject 2 – Unmanaged Device Access

Exercise time: Day 1, 10:30

Inject statement to participants: The access is traced to an unmanaged device using a valid attorney account.

Additional facts available if requested

- Authentication logs show access from an unmanaged laptop and residential ISP not previously associated with the attorney.
- MFA was satisfied through a push approval at 02:15.
- The attorney states they were asleep and did not approve access.
- The same session attempted access to two additional restricted matters but was denied by matter permissions.

Discussion Questions

- 1 Do you disable the attorney account, revoke sessions, or apply conditional restrictions?
- 2 How do SOC, IAM, and legal coordinate containment decisions?
- 3 What forensic steps are needed before resetting credentials or wiping devices?
- 4 How do you determine whether MFA fatigue, token theft, or device compromise occurred?
- 5 What is the escalation threshold for crisis management or executive notification?

Expected Actions / Good Practice Indicators

- Revoke active sessions and rotate credentials for the impacted account.
- Review MFA logs, conditional access events, mailbox rules, and DMS access tokens.
- Preserve identity telemetry and collect endpoint evidence from any firm-managed devices.
- Temporarily increase monitoring on related matter workspaces and privileged users.
- Prepare internal holding lines for practice leaders and client relationship partners.

Facilitator Notes

Assess whether the crisis cell directs business/legal decisions while SOC makes technical containment recommendations. Avoid unrealistic governance where non-technical executives directly order forensic actions without SOC validation.

Inject 3 – Sensitive Matter Exposure

Exercise time: Day 1, 13:00

Inject statement to participants: Affected files include active merger, acquisition, and litigation materials protected by client confidentiality obligations.

Additional facts available if requested

- File inventory shows 2,400 documents accessed or downloaded across eight matter folders.
- A subset includes draft merger term sheets, litigation strategy memos, witness interview notes, and privileged client communications.
- No public leak is known yet, but the data volume suggests potential exfiltration.
- Two clients have board meetings scheduled within 48 hours and may be materially affected if confidentiality is compromised.

Discussion Questions

- 1 How is client impact assessed matter-by-matter?
- 2 Who determines privilege implications and legal hold requirements?
- 3 When do you engage outside breach counsel or cyber insurance?
- 4 What information is needed before notifying clients?
- 5 How do you protect confidentiality while coordinating across practice teams?

Expected Actions / Good Practice Indicators

- Create a matter-level exposure matrix: files, clients, sensitivity, privilege status, deadlines, and relationship owners.
- Engage General Counsel, privacy, ethics/conflicts counsel, and outside counsel as needed.
- Implement legal hold for relevant logs, communications, and forensic artifacts.
- Assess whether any personal information, regulated data, or market-sensitive information is implicated.
- Draft client notification decision memo and regulator/privacy assessment record.

Facilitator Notes

Push participants to separate confirmed access, suspected exfiltration, and confirmed disclosure. Strong responses should document legal rationale and avoid broad statements to clients before facts are validated.

Inject 4 – Client Notification Decision

Exercise time: Day 1, 15:30

Inject statement to participants: Partners assess whether client notification, privilege preservation, and evidence-hold procedures are required.

Additional facts available if requested

- Forensics confirms unauthorized download activity from the unmanaged device session.
- No dark web posting or external publication has been identified.
- The firm cannot yet determine whether downloaded files were shared onward.
- Relationship partners are concerned about client trust and ask whether they should proactively call clients.

Discussion Questions

- 1 Do you notify affected clients now, wait for more evidence, or provide targeted holding statements?
- 2 Who approves client communications and who delivers them?
- 3 What privilege-preserving language must be used in communications?
- 4 Are any regulators, law enforcement, insurers, or professional bodies implicated?
- 5 What remediation commitments can the firm credibly make?

Expected Actions / Good Practice Indicators

- Approve a notification strategy based on matter sensitivity, contractual obligations, professional obligations, and privacy analysis.
- Prepare Q&A; and talking points for client relationship partners.
- Finalize evidence-hold, forensic scope, and monitoring plan.
- Document decisions, rationale, responsible owners, and timelines.
- Initiate corrective actions for unmanaged device access, MFA resilience, DMS anomaly detection, and least privilege.

Facilitator Notes

Evaluate whether participants can make a disciplined notification decision under uncertainty. Encourage a clear distinction between client-care considerations and legally mandated notifications.

5. Key Decision Points

Decision	Owner / Contributors	Inputs Needed	Expected Output
Severity and escalation	Incident lead, SOC, GC, CISO, CIO	Volume, sensitivity, account status, affected users	Severity rating, bridge opened, crisis thresholds documented
Account containment	SOC/IAM with business and legal counsel	Session logs, user validation, MFA evidence	Session suspension, credential reset, conditional access
Evidence preservation	SOC, legal, records, outside counsel	Logs, endpoint evidence, DMS audit trail, cloud metadata	Legal hold, forensic scope, chain-of-custody
Client notification	GC, relationship partner, management	Impact response matrix, obligations, privileged data	No final decision / targeted holding statement with rationale
External reporting	GC, privacy, compliance, insurance	Jurisdiction, data type, contracts, professional liability	Regulator/law enforcement decision record
Remediation	CISO, CIO, DMS owner, IAM, product leaders	Root cause, control failures, user behavior	Corrective action plan with owners and deadlines

Communications Guidance

- Use one approved internal situation report format: facts, assumptions, decisions, open questions, next update time.
- Keep client communications matter-specific, privilege-preserving, and approved by General Counsel.
- Avoid definitive statements such as “no data was exposed” until supported by evidence.
- Maintain a record of who was informed, when, by whom, and with what approved language.
- Ensure relationship partners understand what they may and may not say without legal approval.

6. Debrief and Lessons Learned

Hot Wash Questions

- 1 What decisions were made quickly and confidently?
- 2 Where were roles or authorities unclear?
- 3 What information was missing at each phase, and how did that affect decisions?
- 4 Did the team preserve privilege and evidence while still containing the incident?
- 5 Were client notification criteria understood and actionable?
- 6 What controls would have reduced likelihood or impact?
- 7 What changes should be implemented in the next 30, 60, and 90 days?

Confidence Rating Prompts

- We can detect anomalous bulk access to sensitive matter files.
- We can quickly determine whether access came from a managed or unmanaged device.
- We can revoke sessions and credentials without losing key evidence.
- We understand who approves client communications during a confidentiality incident.
- We can build a matter-level exposure matrix within the first operational period.
- We have tested decision-making for privilege preservation, legal holds, and client notification.

Action Tracker Template

Gap / Observation	Risk	Owner	Due Date	Status

7. MITRE ATT&CK; Mapping

The mapping below reflects the scenario behaviors represented in the STIX bundle and the expanded exercise narrative. It is intended for exercise planning and control validation, not as a finding that these techniques occurred in a real incident.

Tactic	Technique / Sub-technique	Scenario Reflection	Controls to Discuss
Initial Access	T1078 – Valid Accounts	Attorney account used to access confidential matter files	MFA resilience, conditional access, impossible travel, session
Credential Access	T1539 – Steal Web Session Cookie / Token theft (deviceless)	Unauthorized session and MFA satisfied	Token binding, device edge, take, that its possible for sen
Defense Evasion	T1078 – Valid Accounts	Authenticated access blends with legitimate attorney	Behavioral analytics, DMS anomaly detection, privileged wor
Discovery	T1083 – File and Directory Discovery	Attempts to browse multiple restricted matter folders	Matter-level access logging and denied-access alerting.
Collection	T1005 – Data from Local System / T1018 – Data from Information Repositories	Bulk download of information from legal doc	Download tags, redaction, just-in-time access, access rev
Exfiltration	T1041 – Exfiltration Over C2 Channel / T1567 – Exfiltration Over Web Service (possible)	Unauthorized exfiltration over web service (possible)	Fileless, intrusion, through LBN, OASB/SaaS logs, external sharing
Impact	Business impact / confidentiality harm	Privileged matter files may affect M&A, litigation	Client notification, playbooks, design, investigation, crisis c

STIX Source Elements Used

- Identity: Corporate Law Firm / sector: legal-services.
- Threat actor: Commercial Espionage Actor / type: spy / motivation: competitive-advantage.
- Infrastructure: Legal Document Management System.
- Attack pattern: Valid Accounts Used to Access Confidential Matter Files.
- Incident: Law Firm Confidential Matter Access TTX — Unauthorized access to privileged legal matter files is detected from a compromised attorney account..
- Course of action: Matter Access Review and Client Notification Assessment.

End of Exercise Package